LAW IN PLAIN LANGUAGE

General Data Protection Regulation (GDPR)

What this law asks, of whom, and what it gives you

DRAFT. 29 of 114 lines in this document have been approved by a lawyer. Not for publication yet.

This document explains the law in plain language. It is not the law itself, and it cannot tell you how the law applies to your situation. The numbers in brackets are the articles of the law.

In short

- This Regulation protects people when organisations use personal data and allows data to move freely within the Union if protection rules are followed. (art. 1, art. 2, art. 3)
- An organisation may use personal data only on a valid basis. It must be clear, use only necessary data, secure it, and show compliance. (art. 5, art. 6, art. 24, art. 25, art. 32)
- People have rights to information, access, correction, erasure, restriction, portability, and objection. They can complain and go to court. (art. 12, art. 15, art. 16, art. 17, art. 18, art. 20, art. 21, art. 77, art. 79)

What the law is for

Protect personal data and people's fundamental rights, while allowing personal data to move freely within the Union. (art. 1)

Words you need to know

personal data persoonsgegevens
Any information about a person who can be identified directly or indirectly, for example through a name, number, location data, or online identifier. (art. 4)

processing verwerking
Almost any action involving personal data: collecting, storing, using, sharing, changing, restricting, or deleting it. (art. 4)

controller verwerkingsverantwoordelijke
The person or organisation that decides why and how personal data are used. (art. 4)

processor verwerker
The person or organisation that uses personal data on the controller's behalf. (art. 4)

consent toestemming
Freely given, specific, informed, and clear agreement through a statement or active action. (art. 4, art. 7)

The part that matters most

- Use personal data fairly, clearly, and only for specified purposes. Collect no more than needed, keep them accurate, retain them no longer than needed, and secure them. (art. 5, art. 25, art. 32)
- Every processing operation needs a legal basis. Special personal data, such as health data or political views, are prohibited unless a stated exception applies. (art. 6, art. 9)
- Give people understandable information and deal with their rights in time. They can access data, have them corrected or erased, request restriction, move data, and object. (art. 12, art. 13, art. 14, art. 15, art. 16, art. 17, art. 18, art. 20, art. 21)
- Choose processors that provide sufficient guarantees and set out their tasks in writing. Keep a record of processing, except where the exception for smaller organisations applies. (art. 28, art. 30)
- The supervisory authority can restrict or ban processing, issue an order, and impose a fine. For certain infringements, it can reach 20 000 000 EUR or, for an undertaking, up to 4% of total worldwide annual turnover in the preceding financial year, if that is higher. (art. 58, art. 83)

What you must do, and when

IF ...	... THEN
You want to process personal data	You must have at least one legal basis, such as consent, a contract, legal duty, vital interests, a public-interest task, or a legitimate interest that does not outweigh the person's rights; public authorities cannot rely on the latter when performing their tasks. (art. 6)
You collect personal data from someone	You must give clear information when collecting them, including who you are, why and on what basis you use the data, the retention period, rights, and possible recipients, unless that person already has this information. (art. 12, art. 13)

IF …	… THEN
You do not obtain personal data from the person themselves	You must inform that person within a reasonable time and at the latest within one month, or earlier at first contact or first disclosure to a recipient, unless a legal exception applies. (art. 14)
Someone makes a request about their rights	You must make this possible and say what you did with it within one month at the latest. For complex or numerous requests, you may extend the period by another two months if you notify the person within one month. (art. 12, art. 15, art. 16, art. 17, art. 18, art. 20, art. 21, art. 22)
A personal-data breach is likely to create a risk for people	The controller must report it to the competent supervisory authority without undue delay and, where possible, within 72 hours. The processor must inform the controller without undue delay. (art. 33)
The breach is likely to create a high risk for people	The controller must inform affected people without undue delay and in clear, plain language, except in the cases stated by law. (art. 34)
Planned processing is likely to create a high risk	The controller must carry out a data-protection impact assessment before processing. If a high risk remains without measures, it must consult the supervisory authority first. (art. 35, art. 36)

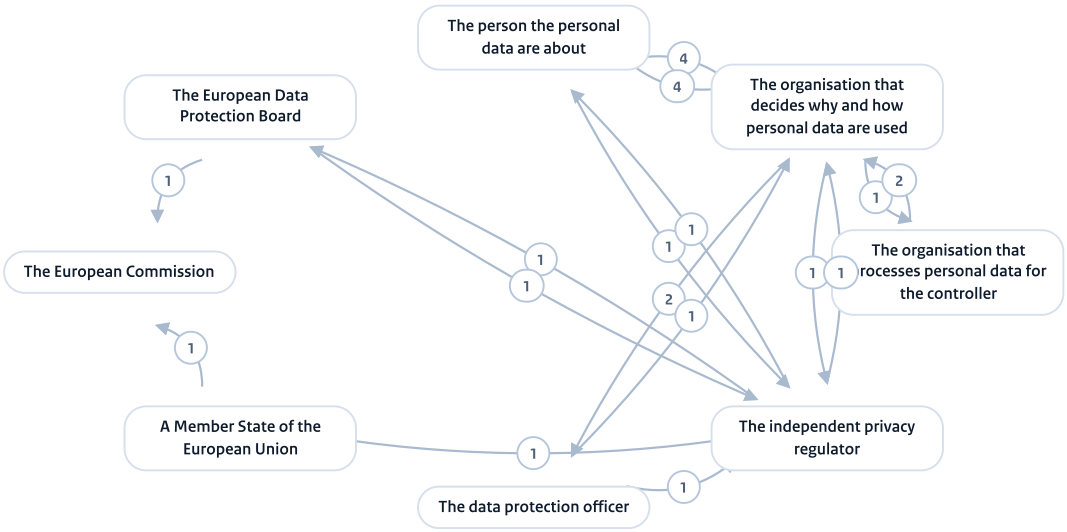
Main exceptions

- The rules do not apply to purely personal or household activities, certain activities outside Union law, certain Member State activities, and processing by competent authorities for criminal offences and penalties. (art. 2)
- Information about data not obtained from the person does not have to be given if that person already has it, this is impossible or requires disproportionate effort under the stated conditions, the law requires the data with safeguards, or confidentiality applies. (art. 14)
- A rights request may be refused or a reasonable fee may be charged if it is manifestly unfounded or excessive. The controller must show this. (art. 12)
- Erasure is not required where processing is necessary for freedom of expression and information, a legal duty, a public-interest task, certain public health purposes, archiving, research, statistics, or legal claims. (art. 17)
- Personal data may be transferred to a third country or international organisation under an adequacy decision or appropriate safeguards. Without that basis, transfer is possible only in the specific situations stated by law. (art. 44, art. 45, art. 46, art. 49)

Where it comes from

- **Charter of Fundamental Rights of the European Union, Article 7:** Protects private and family life, the home, and communications. (Handvest 7)
- **Charter of Fundamental Rights of the European Union, Article 8:** Gives everyone a right to personal-data protection; data must be processed fairly, for specified purposes, and on a legal basis. (Handvest 8)

Who owes what to whom



The person the personal data are about

This person has rights about the use of their personal data.

- → **controller:** may withdraw consent at any time. (art. 7)
- → **controller:** may ask whether personal data are used and request access to them. (art. 15)
- → **controller:** may ask for incorrect personal data to be corrected. (art. 16)
- → **controller:** may, in certain cases, object to the use of personal data. (art. 21)
- → **supervisory authority:** may lodge a complaint if they believe the use of personal data breaches these rules. (art. 77)

The organisation that decides why and how personal data are used

This organisation is responsible for following the rules.

- → **data subject:** must use personal data lawfully, fairly and clearly, and only for a stated purpose. (art. 5, art. 6)
- → **data subject:** must give clear information about the use of personal data. (art. 12, art. 13, art. 14)
- → **data subject:** must erase personal data without undue delay when the conditions for erasure are met. (art. 17)
- → **data subject:** must stop direct marketing when the person objects to it. (art. 21)
- → **processor:** must use only a processor that provides sufficient data protection guarantees. (art. 28)
- → **supervisory authority:** must report a personal data breach, where possible within 72 hours, unless it is unlikely to create a risk. (art. 33)
- → **the data protection officer:** must appoint a data protection officer when the law requires it. (art. 37)
- → **the data protection officer:** must involve the data protection officer in good time and provide the resources to do the work. (art. 38)

The organisation that processes personal data for the controller

This organisation processes data for the controller.

- → **controller:** must process personal data only on written instructions, unless the law requires the processing. (art. 28)
- → **controller:** must report a personal data breach without undue delay. (art. 33)

The independent privacy regulator

This public authority supervises how the rules are applied.

- → **controller:** may order the organisation to correct or erase personal data, or to limit their use. (art. 58)
- → **data subject:** must handle complaints and inform the complainant about progress and the result. (art. 57, art. 77)
- → **the Board:** must send the Board lists of processing operations that need a data protection impact assessment. (art. 35)

The data protection officer

This person advises and monitors data protection within an organisation.

- → **controller:** must inform and advise the organisation about its data protection duties. (art. 39)
- → **supervisory authority:** must cooperate with the regulator and act as a contact point. (art. 39)

A Member State of the European Union

The Member State sets up the regulator and may make additional rules.

- → **supervisory authority:** must designate one or more independent supervisory authorities. (art. 51, art. 52)
- → **the European Commission:** must inform the Commission by 25 May 2018 about legal provisions made under this chapter and without delay about later changes. (art. 51)

The European Data Protection Board

This EU body helps ensure that the rules are applied consistently across the Union.

- → **supervisory authority:** must make a binding decision in certain disputes between supervisory authorities. (art. 65)
- → **the European Commission:** must advise the Commission on data protection in the Union. (art. 70)

The law, chapter by chapter

1. When the privacy rules apply (art. 1–4)

This chapter says when the privacy rules apply, who they apply to, and what important words mean.

2. Basic rules for using personal data (art. 5–11)

- This chapter applies to organisations and public bodies that use personal data, and protects the people whose data they use.
- Personal data may be used only for a valid reason: consent, a contract, a legal duty, vital interests, a public task, or a legitimate interest that does not outweigh the person's rights, where the use is necessary for that reason. Public bodies may not use the last reason when carrying out their tasks. (art. 6)
- Use data fairly, lawfully and transparently. Collect it for clear, legitimate purposes and no more than necessary. (art. 5)
- Do not use data for an incompatible new purpose unless consent or a legal rule permits this under the applicable conditions, and do not keep it longer than necessary, except for archiving in the public interest, research or statistics with suitable protection. (art. 5, art. 6)
- Keep data accurate and update it where needed. Delete or correct inaccurate data without undue delay. Protect it against unauthorised use, loss, destruction or damage. (art. 5)
- When consent is used, the organisation must prove that you gave it. If consent is in a written statement about other matters, the request must be clear and separate; you may withdraw it as easily as you gave it. (art. 7)
- If consent is the basis for online services offered directly to children, consent from a parent is needed if the child is under 16. A national law may set an age from 13 years. (art. 8)
- Sensitive data about, for example, origin, beliefs, health, genetics, biometrics for unique identification, trade-union membership or sex life are prohibited, except where a stated exception applies, such as explicit consent, care or an important public interest. (art. 9)

3. Your rights over personal data (art. 12–23)

- This chapter gives people rights over their personal data and sets out what organisations that use this data must tell them and do.
- An organisation that uses personal data (the controller) must give information and answers clearly, simply, briefly and in an easily accessible way. It must help you exercise your rights. (art. 12)
- If the organisation collects data directly from you, it must immediately tell you who it is, why it uses the data, its basis for doing so, how long it keeps it, who it shares it with, and what rights you have. It must also explain transfers outside the EU, automated decisions and profiling, where these apply. (art. 13)
- If the organisation gets your data from another source, it must also tell you what data it uses and where it came from. It must usually do this within one month, or earlier at first contact or first sharing. Exceptions apply, for example if you already have the information or a law requires secrecy. (art. 14)
- You may ask whether an organisation uses your personal data. If it does, you may see the data and important information about it, and receive a copy. The organisation may charge a reasonable fee for extra copies. (art. 15)
- You may ask for incorrect data to be corrected quickly and incomplete data to be completed. In certain cases, you may ask for data to be erased or its use to be restricted. When use is restricted, the organisation may only use the data, apart from storing it, in limited cases. (art. 16, art. 17, art. 18)
- Erasure is not required where use is needed, among other things, for freedom of expression and information, a legal duty, a task in the public interest, certain research, or a legal claim. Recipients of the data must normally be told about correction, erasure or restriction. (art. 17, art. 19)
- Where the conditions are met, you may receive data you provided in a commonly used, machine-readable format and move it to another organisation. You may object to certain use because of your situation. For direct marketing, the organisation must stop once you object. (art. 20, art. 21)
- You must not be subject to a decision made only by automated processing that affects you legally or significantly. Exceptions exist where this is necessary for a contract, a law allows it and provides safeguards, or you give explicit consent. For a contract or your explicit consent, safeguards must exist, including human intervention, stating your view and challenging the decision. (art. 22)
- The organisation must usually answer your request within one month. It may extend the time by another two months for complex or numerous requests, but must tell you within one month. Requests are free, except where they are manifestly unfounded or excessive: it may then charge a reasonable fee or refuse the request. An EU or Member State law may limit these rights only under strict conditions. (art. 12, art. 23)

4. Using personal data safely and responsibly (art. 24–43)

- This chapter applies to organisations that decide why and how data are used, organisations that process data for them, and in some cases their representatives, data protection officers and regulators.
- An organisation that decides why and how personal data are used (the controller) must take suitable technical and organisational measures. It must be able to show that it follows the rules, review those measures and update them when needed. (art. 24)

- Data protection must be built in when an organisation designs and carries out processing. By default, it may use only personal data needed for a clear purpose, and the data must not be available to an unlimited number of people without human involvement. (art. 25)
- If organisations decide the purpose and means together, they must clearly agree who carries out which data protection task. They must make the main content of that arrangement available. People may exercise their rights against each of those organisations. (art. 26)
- An organisation outside the EU that falls under Article 3(2) must appoint a representative in the EU in writing. This is not required for certain occasional processing with little risk, or for public authorities and public bodies. (art. 27)
- A person or organisation processing data for another organisation (a processor) must provide sufficient safeguards. The organisation outsourcing the processing may choose only such a processor. The arrangements must be in writing, including in electronic form. (art. 28)
- The contract with a processor must state, among other things, what is processed, why and for how long. The processor may follow only written instructions, except where EU or national law requires processing, must arrange confidentiality and security, help with certain data protection tasks, and delete or return data when the service ends unless storage is legally required. (art. 28)
- A processor may not use another processor without prior written permission. That other processor must receive the same data protection duties. The first processor remains responsible if the other processor does not meet its duties. (art. 28)
- Staff and others working under the authority of an organisation or processor who can access personal data may process them only on the controller's instructions. This is different where EU or national law requires the processing. (art. 29, art. 32)
- Controllers and processors must keep a written, including electronic, record of their processing. A controller's record includes, among other things, contact details, purposes, types of data and people, recipients, any transfers, retention periods and security measures. They must give the record to the regulator when asked. (art. 30)
- Organisations with fewer than 250 employees usually do not have to keep this record. The exception does not apply where processing is likely to create risk, is not occasional, or involves sensitive data or data about criminal convictions and offences. (art. 30)
- The controller and processor must cooperate with the regulator when asked. They must also choose security that matches the risk, for example by encrypting data, keeping systems available and testing security regularly. (art. 31, art. 32)
- After a personal data breach, a processor must inform the controller without undue delay. The controller must report a breach likely to create risk to the regulator without undue delay and, where possible, within 72 hours of becoming aware of it. All breaches must be documented. (art. 33)
- Where there is likely to be a high risk, the controller must inform affected people immediately in clear and simple language. This is not required if good protection made the data unreadable to unauthorised people, the high risk has been removed, or individual notification would involve disproportionate effort and a public notice is equally effective. (art. 34)
- Before processing likely to create a high risk, the controller must carry out a data protection impact assessment. This assessment describes the processing, its necessity, the risks and the protective measures. If a high risk remains without measures, the regulator must be consulted first. (art. 35, art. 36)
- A data protection officer must be appointed by many public authorities, for certain large-scale and regular monitoring, and for certain large-scale processing of sensitive or criminal-offence data. This officer advises, monitors compliance, works with the regulator and must be able to work independently. (art. 37, art. 38, art. 39)
- Codes of conduct and certification can help organisations show that they follow the rules. Certification is voluntary and does not remove their own responsibility. A certificate lasts for no more than three years and may be withdrawn if the requirements are no longer met. (art. 40, art. 41, art. 42, art. 43)

5. Personal data sent to other countries and organisations (art. 44–50)

- This chapter concerns organisations that send personal data to third countries or international organisations. It sets conditions so that people's protection is not weakened.
- You may send personal data only if you meet the rules in this chapter. This also applies when the receiving country or organisation sends the data on. (art. 44)
- The Commission may decide that a country, area or organisation provides sufficient protection. You may then send data there without specific authorisation. (art. 45)
- Without such a decision, you may send data only with good protection measures (appropriate safeguards), where people have enforceable rights and effective legal remedies. This can include binding corporate rules, standard clauses, a code of conduct, or certification with binding commitments. (art. 46, art. 47)
- A court ruling or decision by an authority in a third country requiring data can be recognised or enforced only if it is based on an international agreement between that country and the EU or a Member State; other grounds for transfer may still apply. (art. 48)
- If there is no decision or safeguard, a transfer is possible only in specific situations. These include explicit consent after being told about the risks, a necessary contract or legal claim, vital interests where someone cannot give consent, or a public register under its access rules. (art. 49)
- If none of those grounds applies, the organisation deciding on the transfer may send data only exceptionally: not regularly, for few people, for overriding legitimate interests, and with safeguards after an assessment. It must inform the supervisory authority and the person, and record this. (art. 49)
- Public authorities exercising their public powers cannot use the exceptions based on consent, contracts, or that final exceptional ground. (art. 49)

- The Commission monitors protection decisions, may change, suspend or withdraw them, and publishes a list of countries and organisations for which it has decided that they do or no longer provide sufficient protection. (art. 45)

6. Independent privacy regulators (art. 51–59)

This chapter is about independent privacy regulators that oversee rules on personal data, and about what they may do in relation to organisations and people.

7. Cooperation between privacy authorities in Europe (art. 60–76)

This chapter explains how privacy authorities in EU countries work together on cross-border cases, and the role of the European Data Protection Board.

8. Complaints, courts, compensation and fines (art. 77–84)

- This chapter concerns people who believe their personal data are used wrongly, organisations, supervisory authorities and courts.
- You can complain to a supervisory authority where you live, work or the possible breach happened. It must tell you about progress, the outcome and a possible court action. (art. 77)
- You can go to court against a binding decision by a supervisory authority, or if it does not handle your complaint or inform you within three months. (art. 78)
- If an organisation or processor breaches your privacy rights, you can usually go to court in the country where that party is established or where you normally live. (art. 79)
- Anyone who suffers material or non-material damage from a breach has a right to compensation. The organisation is usually liable; a processor is liable in certain conditions. Anyone who proves they bear no responsibility is not liable. (art. 82)
- For breaches, supervisory authorities can impose effective, proportionate and dissuasive fines. They consider, among other things, seriousness, duration, intent, damage reduction, earlier breaches and cooperation. (art. 83)
- Some breaches can lead to a fine of up to 10 000 000 EUR or, for undertakings where this is higher, 2% of worldwide annual turnover. More serious breaches can lead to 20 000 000 EUR or, where this is higher, 4%. Member States also set other penalties. (art. 83, art. 84)

9. Special rules for personal data (art. 85–91)

- This chapter has rules for organisations using personal data in media, official documents, work, research and confidentiality.
- States must balance privacy and free expression. Necessary exceptions may apply to journalistic, academic, artistic or literary expression. (art. 85)
- Bodies with official documents for public tasks may disclose personal data under applicable law, balancing openness and privacy. (art. 86)
- States may make employee-data rules protecting dignity and fundamental rights. (art. 88)
- Archives, research and statistics need safeguards; data must identify people as little as possible. Law may allow necessary exceptions to certain rights if those rights seriously hinder the purposes. (art. 89)
- Churches with detailed privacy rules already in use when the Regulation entered into force may keep them if adapted; independent oversight is required. (art. 91)

10. Supplementary EU rules and oversight (art. 92–93)

This chapter governs the Commission's supplementary rules and the roles of Parliament, Council and a committee.

11. When these privacy rules apply (art. 94–99)

This chapter says when privacy rules apply, which older rules stay in force, and how the Commission reviews them. It matters to people and organisations that process personal data.

Official text: https://eur-lex.europa.eu/legal-content/NL/TXT/?uri=CELEX:32016R0679
Written with AI from the official legal text, checked line by line, and reviewed by lawyers.